

# Koruma ve Güvenlik: Ayrıcalık, Erişim Denetimi ve Bellek Saldırıları

İşletim Sistemleri — Konu 10

## 1. Koruma ile Güvenlik Aynı Şey Değil

İki terim günlük dilde karışır, ders bağlamında ayrıdır:

- Koruma (protection) iç bir mekanizmadır: sistemdeki bir ögenin (süreç, kullanıcı) hangi kaynağa hangi işlemi yapabileceğini denetler. Sorusu "kim neye erişebilir".
- Güvenlik (security) dış bir tehdit modelini içerir: kötü niyetli bir aktörün varlığını varsayar ve kimlik doğrulama, bütünlük, gizlilik gibi başlıkları kapsar. Sorusu "sistem düşmanca bir ortamda ne kadar dayanır".

Koruma, güvenliğin altyapısıdır ama tek başına yetmez: kusursuz bir erişim denetimi, şifresi 1234 olan bir hesabı korumaz.

### 1.1. En Az Ayrıcalık İlkesi

En az ayrıcalık ilkesi (principle of least privilege), her ögenin işini yapmak için gereken en dar yetkiyle çalışmasını söyler. Bir web sunucusunun 80. portu dinlemek için root olması gerekir; ama portu açtıktan sonra ayrıcalığını bırakıp sıradan bir kullanıcı olarak çalışmaya devam etmesi gerekir. Böylece sunucuda bir açık bulunsa bile saldırganın eline geçen yetki sınırlı kalır.

İlkenin ikinci yüzü hataya karşı da koruduğudur: yanlışlıkla yazılmış bir rm komutu, yetkisi dar bir hesapta çok daha az zarar verir.

### 1.2. Kullanıcı Modu ve Çekirdek Modu

Donanım en az iki ayrıcalık seviyesi sunar. Çekirdek modunda (kernel mode) tüm komutlar çalıştırılabilir; kullanıcı modunda (user mode) ayrıcalıklı komutlar — G/Ç, sayfa tablosu değiştirme, kesme maskeleme — donanım tarafından reddedilir.

Bu ayırım yazılımla değil donanımla zorlanır. Yazılımla zorlansaydı, zorlayan yazılımın kendisi de değiştirilebilir olurdu.

Kullanıcı modundaki bir süreç çekirdeğin hizmetine sistem çağrısıyla (system call) ulaşır: özel bir komut (syscall, int 0x80) denetimli bir kapıdan çekirdeğe geçer. Kapı denetimlidir çünkü giriş noktası sabittir; süreç çekirdeğin istediği yerine atlayamaz.

## 2. Eriřim Denetimi Modelleri

Eriřim yetkilerinin tamamı kavramsal olarak bir eriřim matrisidir: satırlar alanlar (domain / kullanıcı), sütunlar nesneler (dosya, aygıt), hücreler izinler.

Matris pratikte seyrek ve bütün hâlinde saklanmaz; iki yoldan biriyle sıkıştırılır.

### 2.1. Eriřim Denetim Listesi (ACL)

Matris sütun sütun saklanır: her nesne, kendisine kimlerin ne yapabileceğini tutar. Unix dosya izinleri (rwx üçlüsü × sahip/grup/diğer) bunun kaba bir hâlidir; POSIX ACL'leri kullanıcı başına girdiye izin verir.

- Avantaj: "bu dosyaya kimler erişebilir" sorusu tek bakışta cevaplanır.
- Dezavantaj: "bu kullanıcı nelere erişebilir" sorusu tüm nesneleri taramayı gerektirir.

### 2.2. Yetenek Listesi (Capability)

Matris satır satır saklanır: her özne, elindeki nesnelere dair devredilebilir biletler (capability) taşır. Bileti göstermek erişim için yeterlidir.

- Avantaj: yetki devri doğaldır ve erişim denetimi hızlıdır.
- Dezavantaj: iptal (revocation) zordur — bilet dağıtılmışsa kimde olduğu bilinmez. Unix'te açık bir dosya tanıtıcısı bir yetenektir ve tam da bu yüzden dosya izinleri sonradan kısıtlansa bile açık tanıtıcı çalışmaya devam eder.

### 2.3. setuid ve Yetki Yükseltme

Unix'te bir çalıştırılabilir dosyaya setuid biti konursa, program çalıştıran kullanıcının değil dosya sahibinin yetkisiyle koşar. passwd komutu böyle çalışır: sıradan bir kullanıcı /etc/shadow dosyasını okuyamaz, ama root'a ait setuid passwd programı aracılığıyla kendi şifresini değiştirebilir.

setuid programlar yetki yükseltme (privilege escalation) açıklarının klasik kaynağıdır: programda bulunan herhangi bir kusur, doğrudan root yetkisiyle sömürülür. Bu yüzden setuid programlar kısa, dar kapsamlı ve az sayıda olmalıdır.

### 3. Bellek Tabanlı Saldırıları

#### 3.1. Yığın Taşması (Buffer Overflow)

Sınırı denetlenmeyen bir kopyalama, tampon sınırının ötesine yazar. Yığın (stack) üzerinde bu, aynı çerçevede duran dönüş adresinin üzerine yazılması demektir. Fonksiyon dönerken denetim saldırganın seçtiği adrese geçer.

```
void oku(void) {  
    char tampon[64];  
    gets(tampon);          /* KUSURLU: girdi uzunluğu hiç denetlenmiyor */  
}
```

gets() girdinin uzunluğunu bilmez ve bilemez; bu yüzden standarttan tümüyle kaldırılmıştır. Doğru karşılığı fgets(tampon, sizeof tampon, stdin)'dir: hedefin boyutu çağrıda açıkça geçer.

Kusurun kaynağı dilin bellek modelidir: C dizilerinde sınır denetimi yoktur ve tampon ile dönüş adresi arasında bir sınır nesnesi bulunmaz.

#### 3.2. Savunma Katmanları

Hiçbiri tek başına yeterli değildir; birlikte kullanılırlar.

- Yığın kanaryası (stack canary): dönüş adresinin hemen önüne rastgele bir değer konur ve dönüşten önce denetlenir. Ardışık bir taşma kanaryayı bozmadan dönüş adresine ulaşamaz.
- DEP / NX (yazılabilir sayfa çalıştırılmaz): yığın ve öbek (heap) sayfaları çalıştırılmaz işaretlenir; saldırganın yığına yerleştirdiği kod çalışmaz.
- ASLR (Address Space Layout Randomization): yığın, öbek ve kütüphanelerin taban adresleri her çalıştırmada rastgeleleştirilir; saldırganın sabit bir adrese atlaması zorlaşır.

DEP'e karşı geliştirilen ROP (Return-Oriented Programming) tekniği yeni kod enjekte etmez; programda hâlihazırda var olan kod parçalarını (gadget) zincirler. Bu, ASLR'nin neden DEP'le birlikte gerektiğini gösterir: gadget'ların adresi bilinmiyorsa zincir kurulamaz.

## 4. Kimlik Doğrulama ve Sistem Sertleştirme

### 4.1. Şifrelerin Saklanması

Şifreler düz metin olarak saklanmaz ve şifrelenerek de saklanmaz — şifreleme geri döndürülebilir olduğu için anahtarı ele geçiren herkes tüm şifreleri okur. Doğrusu tek yönlü bir özet (hash) saklamaktır.

Düz bir hash de yetmez, iki ek gerekir:

- Tuz (salt): her kullanıcı için rastgele bir değer özete karıştırılır. Aynı şifreyi kullanan iki kullanıcının özeti farklı olur ve önceden hesaplanmış tablolarla (rainbow table) toplu kırma işe yaramaz.
- Yavaş fonksiyon: bcrypt, scrypt, argon2 gibi bilinçli olarak pahalı fonksiyonlar kullanılır. Hızlı bir özet fonksiyonu (SHA-256) saldırganın saniyede milyarlarca deneme imkânı verir; yavaş fonksiyon bu sayıyı binlere düşürür.

### 4.2. Çok Faktörlü Kimlik Doğrulama

Faktörler üç sınıftan gelir: bildiğin bir şey (şifre), sahip olduğun bir şey (telefon, donanım anahtarı), olduğun bir şey (parmak izi). İki faktörün aynı sınıftan olması (şifre + güvenlik sorusu) gerçek bir çok faktörlü doğrulama değildir; ikisi de aynı saldırıyla ele geçer.

### 4.3. Kayıt Tutma ve İzleme

Erişim denetimi ihlalleri kaydedilmelidir; kayıt olmadan bir ihlalin olup olmadığı bilinemez. Kayıtların kendisi de bir saldırı hedefidir: saldırganın ilk işi izini silmektir. Bu yüzden kayıtlar yalnız-ekleme (append-only) ortama ya da ayrı bir makineye gönderilir.

Kayıtların gizlilik boyutu da vardır: kaydın içine şifre, oturum anahtarı ya da kişisel veri yazmak, korumaya çalıştığın şeyi düz metin olarak diske yazmak demektir. Kayıt satırında ne olduğu yazılır, veri yazılmaz.